



از ثبت دارایی تا پاسخ کنترل‌شده به تهدید

یک نقشه ساده و عملی برای تیم شبکه و امنیت؛ شامل ساختار شرکت‌ها، اتصال تجهیزات، پایش، تشخیص مهاجم، عملیات و زمان‌بندی.

نسخه منطبق با شاخه main * سپتامبر ۲۰۲۶

اجرای قابل اعتماد

پیش‌نمایش، Connector، PolicyGuard
واقعی، نتیجه و تاریخچه

امنیت قابل اقدام

یافته و مهاجم به ActionPlan کنترل‌شده
و قابل ممیزی تبدیل می‌شود

دید یکپارچه

شرکت‌ها، تجهیزات، پورت‌ها، سلامت و
رخدادها در یک فضای کاری

برنامه چگونه کار می‌کند؟

کاربر از رابط وب وارد می‌شود؛ API هویت و دسترسی را کنترل می‌کند؛ Connectorها با تجهیزات صحبت می‌کنند؛ داده‌ها در PostgreSQL ذخیره و به یافته، مهاجم و اقدام تبدیل می‌شوند.



دستگاه ← جمع‌آوری خواندنی ← Snapshot / Event ← داشبورد، سلامت، پورت‌ها و توپولوژی

مسیر مشاهده

Syslog / Event ← نرمال‌سازی و Finding / Attacker ← Rule ← بررسی شواهد و پاسخ

مسیر امنیت

Catalog یا دستیار ← Preview ← ActionPlan و Connector ← PolicyGuard ← نتیجه و Audit

مسیر عملیات

۳

موفقیت واقعی

موفقیت فقط زمانی معتبر است که Connector اجرا شده و نتیجه ثبت شده باشد.

۲

دو نوع ارتباط

مدیریت برای کشف و اقدام؛ تله‌متری برای Syslog، SNMPv3، gNMI یا Agent.

۱

یک درگاه عمومی

فقط Nginx برای کاربر منتشر می‌شود؛ API و دیتابیس در شبکه داخلی Docker می‌مانند.

اصل معماری

تله‌متری جای اتصال مدیریتی را نمی‌گیرد. برای هر دستگاه یک مسیر مدیریت تست‌شده و یک کانال مکمل پایش تعریف کنید.

کاربر، شرکت و دارایی

هر کاربر می‌تواند چند شرکت داشته باشد. هر شرکت مجموعه مستقل تجهیزات، دارایی‌ها و IP‌های خود را دارد؛ بنابراین گزارش و عملیات در زمینه درست انجام می‌شود.

کاربر سامانه

شرکت ج

فضای کاری جدا با کد یکتای شرکت

شرکت ب

دارایی‌ها و آدرس‌های مستقل از شرکت الف

شرکت الف

روتر، سوئیچ، فایروال و سرورهای مختص شرکت

V

مشاهده‌گر

مشاهده وضعیت و گزارش‌ها بدون اجرای تغییر.

viewer

O

اپراتور

پایش، بررسی یافته و اجرای عملیات مجاز.

operator

A

مدیر

مدیریت کاربران، شرکت‌ها، تنظیمات و عملیات حساس.

admin

رفتار حذف و بازیابی

Soft Delete

حذف عادی شرکت ابتدا آرشیوی است تا پشتیبانی امکان بازیابی داشته باشد.

حذف دائمی

حذف آبشاری می‌تواند شرکت و دارایی‌های وابسته را پاک کند؛ فقط مدیر و با تأیید نام شرکت.

تمام درخواست‌ها باید با نشست معتبر، CSRF و مجوز مرکزی انجام شوند.

روش صحیح شروع کار

۱ شرکت را بسازید

نام روشن و کد کوتاه یکتا انتخاب کنید.

۲ شرکت فعال را انتخاب کنید

پیش از ثبت دستگاه، زمینه سازمانی را بررسی کنید.

۳ دارایی‌ها را ثبت کنید

هر تجهیز باید به شرکت درست متصل باشد.

۴ دسترسی را محدود کنید

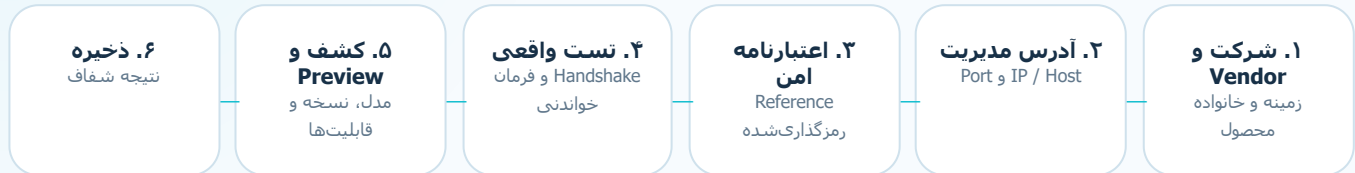
کمترین سطح دسترسی لازم را اختصاص دهید.

قبل از هر عملیات اجرایی

بالای صفحه نام شرکت و دستگاه انتخاب‌شده را کنترل کنید. این ساده‌ترین راه جلوگیری از تغییر روی تجهیز اشتباه است.

ثبت دستگاه و دو مسیر اتصال

ثبت درست یعنی: هویت دستگاه، credential امن، تست واقعی اتصال، تشخیص Vendor و نمایش Preview پیش از ذخیره.



T

مسیر دوم: تله‌متری و رویداد

برای مشاهده مداوم، رخدادهای امنیتی و Metricها.

Agent gNMI SNMPv3 Syslog

M

مسیر اول: مدیریت و کنترل

برای کشف هویت، دریافت وضعیت و اجرای عملیات کنترل‌شده.

XML API NETCONF REST API SSH/CLI

Vendor	مسیر مدیریت	کانال مکمل	نکته عملی
Linux	SSH با کلید خصوصی	Agent یا Syslog امن	برای sudo مجوز محدود تعریف شود.
Cisco	SSH/CLI	RESTCONF/NETCONF، SNMPv3، Syslog، gNMI	کانال مدل‌محور حسب مدل و نسخه.
MikroTik	SSH؛ HTTPS REST برای Inventory	Syslog و SNMPv3	REST فعلی برای خواندن است.
FortiGate	SSH/CLI	Syslog و API Token، SNMPv3	Trusted Host و least privilege.
Sophos	XML API	REST/SNMPv3/Syslog حسب نسخه	IP سرور برنامه مجاز شود.

Credential را داخل نام، توضیح یا Log ننویسید

رمز و Token باید در Credential Store رمزگذاری‌شده نگهداری و فقط به صورت Reference استفاده شوند.

از داشبورد تا جزئیات دستگاه

داشبورد برای تصمیم سریع است؛ صفحه دستگاه برای بررسی عمیق. داده زنده را از زمان آخرین جمع‌آوری و وضعیت Connector تشخیص دهید.

۴

جمع‌آوری تازه

۳

بازکردن دستگاه

۲

بررسی داشبورد

۱

انتخاب شرکت

فضای کاری دستگاه

✓ هویت: Vendor، مدل، سریال و نسخه

✓ اینترفیس‌ها و وضعیت Up / Down

✓ ARP، Route، VLAN، Inventory و همسایه‌ها حسب Vendor

✓ تاریخ آخرین بررسی و وضعیت اتصال

داشبورد چه می‌گوید؟

✓ تعداد و وضعیت تجهیزات

✓ پورت‌های پرترافیک واقعی در ۲۴ ساعت اخیر

✓ سلامت سرورهای Linux و مصرف CPU / Memory / Disk

✓ یافته‌ها و رویدادهای نیازمند توجه

اقدام

فقط در صورت نیاز

جمع‌آوری داده

Snapshot تازه بگیرید

جزئیات دستگاه

شواهد و تنظیمات را بررسی کنید

دارایی‌ها

شرکت و دستگاه را پیدا کنید

داشبورد

ناهنجاری را ببینید

عدد بدون زمان، داده عملیاتی نیست

همیشه «آخرین جمع‌آوری موفق»، وضعیت Connector و عمر Snapshot را کنترل کنید؛ داده قدیمی نباید مبنای تغییر حساس باشد.

C

قابلیت‌ها

Read-only، اجرایی یا پشتیبانی‌نشده بودن هر بخش شفاف است.

H

سلامت

امتیاز کلی را با Metric خام و زمان Snapshot تطبیق دهید.

P

پورت‌ها

Up/Down، توضیح، VLAN و ترافیک را کنار هم ببینید.

مهاجمان، Brute Force و یافته‌ها

رویداد خام به‌تنهایی هشدار نیست. موتور تشخیص رخدادها را بر اساس Vendor، سرویس، IP منبع، تعداد تلاش و بازه زمانی هم‌بسته می‌کند.

Response
ActionPlan کنترل‌شده

Finding / Attacker
شواهد و ریسک

Detection Rule
Window و Threshold

Normalization
IP، کاربر، سرویس و نتیجه

Syslog / Event
دریافت از Linux و Vendor

قبل از مقابله بررسی کنید

- ✓ IP عمومی یا داخلی و مالک آن
- ✓ False Positive مانند Scanner مجاز
- ✓ دستگاه‌ها و سرویس‌های هدف
- ✓ اثر Block روی مدیریت یا کاربران واقعی

نشانه‌های Brute Force

- ✓ تلاش‌های ناموفق تکراری از یک IP
- ✓ SSH، WinBox، GUI، API یا VPN authentication failure
- ✓ عبور از آستانه در بازه زمانی Rule
- ✓ هم‌بستگی بین Vendor و سرویس هدف

۱. مهاجم را باز کنید

شدت، تعداد رخداد، اولین و آخرین مشاهده و سرویس‌های هدف را ببینید.

۲. شواهد را اعتبارسنجی کنید

پیام‌های خام محدودشده، Finding مرتبط و دستگاه هدف را تطبیق دهید.

۳. پاسخ مناسب بسازید

Block موقت IP یا سخت‌سازی را به شکل ActionPlan بسازید؛ فرمان خام اجرا نکنید.

۴. نتیجه را دنبال کنید

Audit، نتیجه Connector و کاهش رخدادها را بعد از اقدام کنترل کنید.

IP مدیریتی خودتان را مسدود نکنید

PolicyGuard دوباره بررسی می‌شود، اما اپراتور همچنان باید Trusted Source، مسیر مدیریت و امکان Rollback را کنترل کند.

مرکز عملیات و دستیار هوشمند

دستیار فرمان خام را مستقیم روی دستگاه اجرا نمی‌کند. خروجی مفید آن یک ActionPlan ساخت‌یافته است که قابل بازبینی، تکمیل، کنترل و ثبت باشد.



وضعیت	معنی ساده	کار اپراتور
proposed / needs input	برنامه ساخته شده اما اطلاعات کم است.	دستگاه و پارامترهای لازم را تکمیل کنید.
awaiting approval	برنامه معتبر و منتظر تصمیم است.	Preview و Risk را بازبینی کنید.
running	Connector در حال اجراست.	از اجرای تکراری پرهیز کنید.
succeeded / failed	نتیجه واقعی ثبت شده است.	خروجی، Verification و Audit را ببینید.
blocked	مرز ایمنی یا قابلیت مانع اجراست.	علت را رفع کنید؛ محدودیت را دور نزنید.

قانون اعتماد

Preview به معنای اجرا نیست؛ موفقیت نیز بدون connectorInvoked=true معتبر نیست.

زمان‌بندی عملیات آماده و ساخته شده با دستیار

صف زمان‌بندی فقط عملیات اجرایی و اثرگذار را می‌پذیرد. عملیات صرفاً مشاهده‌ای، ناقص یا بدون Connector از فهرست حذف می‌شوند.

مسیر دستیار هوشمند

۱ «ساخت عملیات با دستیار»

هدف را با زبان ساده توضیح دهید.

۲ ActionPlan را کامل کنید

فقط برنامه قابل اجرا وارد فهرست می‌شود.

۳ «زمان‌بندی این عملیات»

برنامه خودکار انتخاب و به فرم بازگردانده می‌شود.

مسیر عملیات آماده

۱ دستگاه را انتخاب کنید

فهرست عملیات مجاز همان Vendor بارگذاری می‌شود.

۲ پارامترها را وارد کنید

مقادیر هنگام تغییر ساعت حفظ می‌شوند.

۳ تاریخ و ساعت را تعیین کنید

شمسی یا میلادی، ساعت ۲۴ ساعته و منطقه زمانی.

تاریخچه

موفق، ناموفق یا رد شده

بررسی زمان اجرا

PolicyGuard و Permission

ثبت در صف

حالت انتظار

تعیین زمان

Jalali / Gregorian

ساخت با انتخاب

Catalog / Assistant

تاریخچه دائمی

Trigger، ActionPlan، خطا و نتیجه
Connector قابل پیگیری است.

اجرای زمان مقرر

اتصال و مجوز دوباره بررسی می‌شود؛ ثبت
قبلی تضمین اجرا نیست.

برنامه‌های آینده

توقف، فعال‌سازی، اجرای اکنون و لغو در
یک فهرست داخلی.

برای تغییرات حساس پنجره نگهداری تعریف کنید

Backup، مسیر دسترسی جایگزین، Rollback و Verification را پیش از زمان‌بندی خاموشی پورت یا سرویس آماده کنید.

استقرار Docker و چک‌لیست بهره‌برداری

چهار سرویس اصلی با Compose بالا می‌آیند. فایل‌های secret و env هرگز در Git قرار نمی‌گیرند و باید روی سرور ساخته یا از Secret Store امن تحویل شوند.

راه‌اندازی روی سرور

سرویس‌های مورد انتظار

- ✓ **main-nginx** — درگاه HTTP برنامه
- ✓ **firewall-web** — رابط React تولیدشده
- ✓ **firewall-api** — API، Worker و Connectorها
- ✓ **firewall-db** — PostgreSQL و داده پایدار

وضعیت درست

هر چهار سرویس باید healthy باشند.

```
git clone --depth 1 --branch main --single-branch \
https://github.com/alirezaaliverdy-
glitch/track_firewall_log.git track
cd track

# backend/.env و secretها را قرار دهید
docker compose -f docker-compose.firewall.yml up -d --
build
docker compose -f docker-compose.firewall.yml ps
```

چک پیش از تغییر

- ✓ شرکت و دستگاه هدف درست است
- ✓ Backup و Rollback آماده است
- ✓ دسترسی جایگزین مدیریتی وجود دارد
- ✓ Preview و Risk بازبینی شده است
- ✓ پنجره نگهداری و مسئول اجرا مشخص است

چک روزانه

- ✓ سلامت چهار کانینر و فضای دیسک
- ✓ آخرین جمع‌آوری موفق دستگاه‌ها
- ✓ Findingهای High / Critical
- ✓ اجرای ناموفق تسک‌های زمان‌دار
- ✓ صف اعلان‌های ایمیلی

۳

ممیزی

Audit و تاریخچه عملیات را برای پاسخ‌گویی و عیب‌یابی نگه دارید.

۲

به‌روزرسانی

ابتدا commit/branch را کنترل، سپس imageها را rebuild و health را بررسی کنید.

۱

پشتیبان‌گیری

از volume دیتابیس و storageهای برنامه Backup دوره‌ای بگیرید.

سه چیز را هرگز داخل Git نگذارید

رمز دستگاه‌ها، Tokenهای API و مقادیر فایل env تولیدی. مخزن فقط کد و نمونه تنظیمات را نگه می‌دارد.